

Digital Behavioral Baseline

Catching account takeovers by how people behave, not by the password they type.

By Travis · pandas · scikit-learn · Isolation Forest

A stolen password logs in just like the real one. This project learns what's normal for **each user**: when they log in, from where, on what device, how fast they work, and which pages they use. Then it flags sessions that don't fit. A triage layer ranks every flag and explains it in plain language for an analyst.

13 / 20

planted attacks caught at a 3.75% review budget

100%

of caught attacks ranked HIGH priority after triage

11 / 11

false alarms from employees back from leave, cleared by one rule

0 / 4

quiet Explorers caught. Human-speed attackers are the blind spot.

HOW IT WORKS

01

Generate

50 users in 5 roles, 44 days of logs, attacks planted in the last 14

02

Measure

13 behavior features per session, compared to each user's own history

03

Model

Isolation Forest trained only on normal sessions, never on attacks

04

Triage

HIGH / MEDIUM / LOW priority with plain-English reasons

05

Evaluate

Answer key opened last: caught, missed, false alarms

What it caught, by attack type

Explorer · loud		6/6
Bot · loud		2/2
Guesser		3/3
Bot · quiet		2/5
Explorer · quiet		0/4

Every loud attack was caught. Every miss moved at human speed.

How triage sorted the 35 flags

Real attack

Normal user

HIGH		18
MEDIUM		6
LOW		11

HIGH: all 13 real attacks, plus 5 finance quick exports. MEDIUM: remote switchers and a traveler. LOW: employees back from leave who forgot their password.

The most useful result was a failure

VERSION 1 · ROC-AUC 1.000

Too perfect to trust. Normal users never touched sensitive pages, so one feature gave the answer away. The test was too easy.

VERSION 2 · ROC-AUC 0.976

Added finance and IT roles, leave returns, remote workers, and quiet attackers. The model started missing things, and the results became worth trusting.

"It learns what normal looks like, then flags what doesn't fit. It finds unusual, not bad."

LIMITS, STATED UP FRONT

Synthetic data

Shows the method works, not how it would perform on real company logs.

Normal is learned once

One user who switched to remote work was flagged 8 times. Next step: a rolling baseline.

Rules can be gamed

Slow failed logins from a victim's own device read as LOW. An insider could hide there.